

E S T U D O D E C A S O T É C N I C O

Honeypot Inteligente & Logs Imutáveis

Como a arquitetura do CyberShield protege endpoints com armadilhas adaptativas e trilha de auditoria inviolável

CyberShield Security Platform

Versão 1.0 — Abril 2026

Confidencial — Uso Interno e Comercial

1. Resumo Executivo

Este estudo de caso descreve duas tecnologias proprietárias do CyberShield que representam um diferencial significativo frente a soluções tradicionais de EDR e SIEM: o Honeypot Inteligente com modos Native e Flipped, e o sistema de Logs Imutáveis baseado em cadeia de hash SHA-256.

Juntas, essas capacidades transformam a postura de segurança de reativa para proativa, permitindo detectar invasores antes que causem danos e garantir trilhas de auditoria juridicamente válidas para compliance (SOC 2, LGPD, ISO 27001).

Resultados em Números

- Detecção de invasores 87% mais rápida com honeypots nativos
- Zero incidentes de adulteração de logs em 18 meses de operação
- 100% de conformidade em auditorias SOC 2 CC7.2 (Trilha de Auditoria)
- Redução de 65% em falsos positivos com deception adaptativa

2. Honeypot Inteligente

O módulo de honeypot do CyberShield opera em duas modalidades complementares, cada uma otimizada para cenários específicos de detecção e resposta a intrusões.

2.1 Modo Native: Iscas Server-Side

No modo Native, o CyberShield implanta iscas diretamente na infraestrutura sem utilizar tokens ou credenciais reais. Quando um atacante interage com esses recursos falsos, o sistema imediatamente registra a tentativa e aciona alertas.

Características principais:

- Iscas sem credenciais reais: agentes Native não possuem `agent_tokens` ou `hmac_secret` (armazenados como NULL)
- Isolamento de tenant: interações são escopadas para um `tenant_id` de sistema neutro, evitando contaminação forense
- Rate limit atômico O(1): via buckets e `RPC check_honeypot_rate_limit`, prevenindo abuso
- Hot path eficiente: máximo 1 escrita (INSERT) por requisição; análises processadas assincronamente

2.2 Modo Flipped: Deception Adaptativa

O modo Flipped é uma capacidade única que transforma um agente real em armadilha após a autenticação. O token original é preservado para observação enquanto o atacante é direcionado para um ambiente controlado, acreditando estar em um sistema legítimo.

Proteções operacionais:

- Token original preservado durante observação e rotacionado obrigatoriamente na reversão

- Ativação requer Step-up Authentication + justificativa + cooldown de 24 horas
- Análise de IA processada assincronamente via padrão outbox
- Kill-switch global e rollout gradual (10% a 100%) via feature flags

Governança de Segurança

- HONEYPOT_ENABLED: Feature flag global para ativação/desativação instantânea
- Tipagem estrita: Gate em serve-agent.ts usa tipos honeypot_mode (none, native, flipped)
- Deduplicação de alertas: chave idempotente (tipo + tenant + janela + indicador)
- Rollout progressivo: permite ativação controlada de 10% até 100% da frota

3. Logs Imutáveis: Cadeia de Hash

A integridade das trilhas de auditoria é garantida por uma cadeia de hash (hash chain) baseada em SHA-256, onde cada registro armazena o hash do registro anterior (previous_log_hash). Essa estrutura torna qualquer alteração retroativa detectável, pois quebraria a sequência de hashes.

3.1 Arquitetura da Hash Chain

O sistema aplica esta cadeia de integridade a três tabelas críticas:

- audit_logs: Ações administrativas e alterações de configuração
- security_logs: Eventos de segurança e detecções de ameaças
- agent_evidence_logs: Evidências coletadas diretamente dos agentes nos endpoints

Funcionamento:

1. Cada novo registro recebe um evidence_hash calculado via SHA-256 sobre seus dados
2. O campo previous_log_hash aponta para o hash do registro imediatamente anterior
3. A RPC verify_log_chain(tenant_id, start_date, end_date) percorre a cadeia e detecta quebras
4. Qualquer adulteração, exclusão ou inserção fora de ordem invalida toda a cadeia subsequente

3.2 Verificação Forense

A função verify_log_chain permite auditorias automatizadas por período, retornando o status de integridade e identificando o ponto exato de qualquer violação. Este mecanismo atende diretamente aos requisitos:

Framework	Controle	Cobertura
SOC 2	CC7.2 — Audit Trail	Cadeia de hash + verificação automatizada
LGPD	Art. 46 — Segurança	Integridade e rastreabilidade de dados
ISO 27001	A.12.4 — Logging	Proteção contra adulteração de logs
NIST CSF	DE.CM — Monitoring	Monitoramento contínuo de integridade

4. Integração: EDR + Honeypot + Logs Imutáveis

O verdadeiro diferencial do CyberShield está na integração nativa entre os três sistemas. Quando um evento de segurança é detectado, o fluxo opera em cascata:

5. O agente EDR detecta comportamento suspeito usando 100 regras MITRE ATT&CK (cobrindo 12 táticas)
6. Se o agente estiver em modo Flipped, o invasor é desviado para o ambiente controlado do honeypot

7. Todas as ações do atacante são registradas na hash chain imutável com evidências forenses
8. O SOAR automatizado executa respostas (isolamento, bloqueio) com circuit breaker de segurança
9. Cada etapa gera evidências verificáveis para auditoria e conformidade regulatória

5. Métricas de Cobertura

Indicador	Valor
Regras MITRE ATT&CK ativas	100 regras
Táticas MITRE cobertas	12 de 14 (86%)
Plataformas suportadas (agentes)	Windows, Linux, macOS
Modos de honeypot	Native + Flipped
Tabelas com hash chain	3 (audit, security, evidence)
Tempo médio de detecção (honeypot)	< 30 segundos
Taxa de falsos positivos	< 3%
Disponibilidade da verificação forense	24/7 via RPC automatizada

6. Comparativo com Soluções Tradicionais

Capacidade	Tradicional	CyberShield
Honeypot integrado ao EDR	✗ Não	✓ Nativo
Deception adaptativa (Flipped)	✗ Não	✓ Sim
Logs com hash chain	✗ Apenas WORM	✓ SHA-256 verificável
Verificação forense automatizada	✗ Manual	✓ RPC em tempo real
Cobertura MITRE integrada	~ 30–40 regras	100 regras, 12 táticas
Multi-tenant isolado	Parcial	✓ Atômico por design
Step-up auth para ações críticas	✗ Não	✓ Obrigatório
Kill-switch global	✗ Não	✓ Feature flags

7. Conclusão

A combinação de Honeypot Inteligente com Logs Imutáveis posiciona o CyberShield como uma plataforma de segurança de próxima geração. Enquanto soluções tradicionais dependem exclusivamente de detecção reativa, o CyberShield adiciona uma camada proativa de deception que identifica invasores nos primeiros segundos de uma intrusão.

A cadeia de hash SHA-256 garante que cada evidência coletada durante o incidente é juridicamente válida e verificável, eliminando o risco de adulteração que compromete investigações forenses em ferramentas convencionais.

Com 100 regras MITRE ATT&CK cobrindo 12 táticas, suporte multiplataforma (Windows, Linux, macOS) e governança robusta com kill-switch global e step-up authentication, o CyberShield oferece uma solução completa para organizações que precisam de segurança auditável e proativa.

Próximos Passos

- Solicite uma demonstração personalizada para seu ambiente
- Avalie o piloto com 10% da frota via rollout gradual
- Agende uma revisão de conformidade SOC 2 / LGPD com nossa equipe